Linux Privilege Escalation via /etc/passwd and /etc/shadow

1. Lab Overview

- **Platform:** TryHackMe
- **Category:** Linux Privilege Escalation
- **Focus:** Weak permissions and password security
- **Target Files:** `/etc/passwd`, `/etc/shadow`
- **Status:** Lab Completed

2. Description

This lab explores Linux privilege escalation techniques involving the `/etc/passwd` and `/etc/shadow` files. These files contain important account information and password-related data used by the Linux authentication system.

Misconfigured permissions or insecure account entries can allow a local attacker to gain unauthorized access or potentially escalate privileges to root.

3. Vulnerability Analysis

`/etc/passwd`

The `/etc/passwd` file stores user account information, including usernames, user IDs (UIDs), group IDs (GIDs), home directories, and login shells.

Although this file is normally readable by all users, unauthorized write access can create a serious security weakness. For example, an attacker may abuse a writable account entry or introduce an improperly configured account with UID `0`, which represents root privileges.

`/etc/shadow`

The `/etc/shadow` file stores password hashes and password-aging information. It should normally be accessible only to privileged users or a specifically authorized group.

If an unprivileged user can read or modify this file, password hashes may be exposed or authentication security may be compromised.

4. Exploitation Methodology

1. Enumerated local user accounts and inspected file permissions.
2. Checked access controls on `/etc/passwd` and `/etc/shadow`.
3. Identified the misconfiguration present in the lab environment.
4. Investigated how the weakness could be abused to affect account authentication or privilege assignments.
5. Applied the lab's intended technique and verified the resulting privilege level.

5. Impact

Depending on the specific misconfiguration, an attacker with local access may be able to:

- Obtain password hashes for offline password-cracking attempts.
- Modify account information or authentication settings.
- Create or manipulate privileged accounts if sufficient write access exists.
- Escalate privileges to root and gain full system control.

6. Remediation

- Ensure `/etc/passwd` is writable only by authorized privileged processes.
- Restrict `/etc/shadow` access to root and appropriately authorized services or groups.
- Regularly audit file permissions and ownership.
- Monitor unexpected changes to system account files.
- Investigate suspicious accounts with UID `0`.
- Apply least-privilege principles and maintain secure authentication practices.

7. Key Takeaways

This lab demonstrates how insecure permissions and account-file misconfigurations can expose critical weaknesses in Linux authentication. Proper file permissions, account auditing, and privilege management are essential to preventing local privilege escalation.

8. References

- TryHackMe
- Linux `passwd` Manual
- Linux `shadow` Manual